

# **NHID-Auth v1.0**

## **Authorization Layer Specification**

Companion Specification to NHID-Clinical v1.3  
Delegated Authority Verification for Healthcare Voice AI

Author: Brianna Baynard

Published: May 2026

License: CC BY 4.0

DOI: [Pending Zenodo Assignment]

# Abstract

NHID-Auth addresses the authorization gap identified in NHID-Clinical v1.3: the ability to verify that an AI voice agent calling on behalf of a healthcare provider has legitimate delegated authority to access operational data. This companion specification defines a minimum viable attestation format for proof of delegation, separate from the behavioral disclosure requirements in NHID-Core. The authorization layer is intentionally decoupled to allow vendors to implement disclosure controls immediately while authorization infrastructure matures through real-world feedback.

## 1. The Authorization Problem

NHID-Clinical v1.3 Core requires AI voice agents to disclose their non-human identity before data exchange. However, disclosure alone does not solve the verification problem: **How does the receiving party confirm the AI agent is authorized to represent the claimed provider?**

Public identifiers like National Provider Identifier (NPI) do not prove authorization. Anyone can Google a provider's NPI and claim to call on their behalf. This creates an NPI spoofing vulnerability where unauthorized systems can extract protected operational data by naming a valid provider without proving delegation.

## 2. Core Principle: Identity $\neq$ Authorization

The fundamental distinction this specification makes:

**Identity:** Who or what is calling (answered by NHID-Clinical disclosure)

**Authorization:** Does the caller have permission to act on behalf of the named entity?

Public identifiers establish identity. Authorization requires proof of delegation.

### 3. Authorization Model Requirements

A valid authorization attestation MUST contain five elements:

| Element               | Description                                  | Example                                        |
|-----------------------|----------------------------------------------|------------------------------------------------|
| Delegating Entity     | Who granted permission                       | Provider NPI or Payer Organization ID          |
| Authorized Actor      | System acting on behalf of delegating entity | Vendor platform ID or AI system identifier     |
| Scope                 | What actions are permitted                   | ['claims_inquiry', 'eligibility_check']        |
| Duration              | Validity period with start/end timestamps    | 2026-05-01T00:00:00Z to 2027-05-01T00:00:00Z   |
| Revocation Capability | Mechanism for immediate invalidation         | Reference ID for lookup or revocation endpoint |

### 4. Minimum Viable Attestation Format

NHID-Auth v1.0 defines a baseline attestation format that requires no cryptographic infrastructure. Organizations can upgrade to JWT, PKI, or registry-based verification later without breaking backward compatibility.

**JSON Attestation Structure:**

```
{
  "delegating_entity": "Provider_OR_Payer_ID",
  "authorized_actor": "Vendor_OR_AI_System_ID",
  "scope": ["claims_inquiry", "eligibility_check"],
  "issued_at": "2026-05-01T00:00:00Z",
  "expires_at": "2027-05-01T00:00:00Z",
  "revocable": true,
  "reference_id": "AUTH-2026-000001"
}
```

### 5. Validation Requirements (Conceptual)

Receiving parties validating an authorization attestation SHOULD verify:

- 1. **Existence of Delegation:** Attestation is present and parseable
- 2. **Scope Limitation:** Requested action matches permitted scope
- 3. **Temporal Validity:** Current timestamp falls within issued\_at and expires\_at window
- 4. **Revocation Awareness:** Attestation has not been invalidated (if revocation mechanism exists)

Note: This specification defines the attestation format but does not mandate a specific validation infrastructure. Organizations may validate via internal databases, third-party registries, or bilateral agreements.

## 6. Design Intent and Future Evolution

NHID-Auth v1.0 is intentionally minimal to enable immediate adoption while the ecosystem develops verification infrastructure. Key design principles:

- Portable:** No cryptographic infrastructure required at baseline
- Audit-Friendly:** Human-readable JSON for compliance review
- Extensible:** Upgrade path to JWT, PKI, or registry-based systems
- Decoupled:** Authorization layer independent of NHID-Core behavioral requirements

**Future Evolution (v1.1+):**

- JWT-based attestations with signature verification
- Central registry for real-time authorization lookup
- Scope negotiation protocols
- Revocation APIs and certificate revocation lists
- Integration with FHIR authorization frameworks

## 7. Relationship to NHID-Clinical v1.3 Core

NHID-Auth is a companion specification, not a replacement. The two layers work together:

| Layer          | Addresses                                                                   | Status                           |
|----------------|-----------------------------------------------------------------------------|----------------------------------|
| NHID-Core v1.3 | Behavioral disclosure (who is calling, when they call, how they call)       | Stable, implemented              |
| NHID-Auth v1.0 | Authorization verification (proof of delegation to a behavioral disclosure) | Baseline infrastructure maturing |

Organizations can implement NHID-Core behavioral controls immediately and adopt NHID-Auth authorization verification when organizational partnerships and verification infrastructure are ready.

## 8. Implementation Guidance

### Vendor Implementation:

1. Generate attestation JSON with delegating\_entity from provider contract
2. Include reference\_id for audit trail
3. Set scope to minimum actions required (principle of least privilege)
4. Implement expiration and renewal workflow
5. Provide revocation endpoint or invalidation mechanism

### Payer/Receiver Implementation:

1. Request authorization attestation during call
2. Validate attestation structure and required fields
3. Check scope matches requested action
4. Verify temporal validity (issued\_at, expires\_at)
5. Log reference\_id for audit purposes

## 9. References

- NHID-Clinical v1.3 Core Specification
- OAuth 2.0 Authorization Framework (RFC 6749)
- JSON Web Token (JWT) Specification (RFC 7519)
- NIST Special Publication 800-63-3: Digital Identity Guidelines
- HIPAA Security Rule: Access Control Standards (45 CFR §164.308(a)(4))

## 10. License and Attribution

This specification is released under Creative Commons Attribution 4.0 International (CC BY 4.0).  
Suggested citation:

*Baynard, B. (2026). NHID-Auth v1.0 Specification: Authorization Layer for Healthcare Voice AI. nhid-clinical.org. CC BY 4.0.*

## 11. Contact Information

**Technical Questions:** [help@nhid-clinical.org](mailto:help@nhid-clinical.org)

**Website:** [nhid-clinical.org](https://nhid-clinical.org)

**Community:** Discord ([discord.gg/eP8FxXkGU6](https://discord.gg/eP8FxXkGU6)) | Reddit ([r/NonHumanAuth](https://www.reddit.com/r/NonHumanAuth))